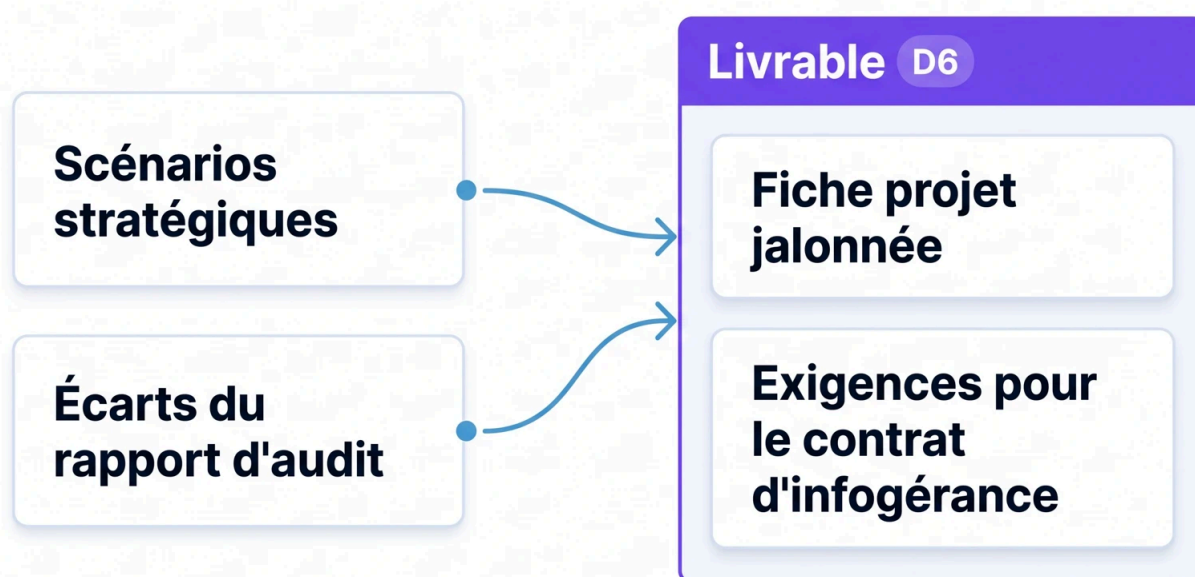


Exigences tiers et fiche projet (D6)

✓ Du scénario au document qui engage



Zéro exigence orpheline

Objectifs de la séance

À l'issue de ce TP :

- **Produire** une fiche projet dotée de jalons de sécurité et de critères de passage vérifiables
- **Rédiger** un jeu d'exigences de sécurité pour un contrat d'infogérance, tracé vers l'analyse de risque
- **Justifier** chaque exigence par un scénario stratégique de l'atelier 3 ou un écart du rapport d'audit de la séance 4
- **Enrichir** la note de stratégie du groupe de sa sous-section « tiers et projets »

Prérequis

- Le TP précédent : l'étude EBIOS RM enrichie de son écosystème coté, de ses scénarios stratégiques et d'un premier scénario opérationnel.
- Le cours de ce matin : les six jalons de sécurité et leurs critères de passage, les trois régimes de projet.
- Le rapport d'audit de la séance 4, dont les écarts qualifiés servent de justification aux exigences.
- La note de stratégie du groupe, enrichie jusqu'à la séance 5, à prolonger en fin de séance.

Ce qui se remet aujourd'hui

Le livrable D6 se compose de deux pièces écrites, cohérentes entre elles, et de l'export ou de la capture de l'étude EBIOS RM saisie au TP précédent, parties prenantes cotées et scénarios stratégiques. Une fiche projet, qui applique le Security by Design à un projet réel du groupe. Un jeu d'exigences de sécurité pour un contrat d'infogérance, complété du dispositif de surveillance du tiers, qui applique la maîtrise des tiers à une prestation réelle du groupe. Les deux partagent un principe : rien ne s'y affirme qui ne soit tracé vers un risque identifié ou un écart constaté. Un jalon sans critère de passage, ou une exigence sans justification, est un vœu, et la grille d'acceptation le refuse.

✓ Pièce 1 : la fiche projet

La fiche projet applique le Security by Design à un projet réel de la filiale instruite, celui que le dossier de filiale porte. Cadrer ce projet comme s'il était à lancer aujourd'hui, avec la discipline des jalons : chaque jalon reçoit un critère de passage qui se démontre par un fait, jamais par une déclaration. Renseigner les deux gabarits ci-dessous ; pour un système soumis à homologation, le critère du jalon J4 est la décision d'homologation prononcée par l'autorité désignée en séance 4. À produire : la fiche projet complète, rubriques et six jalons renseignés, chacun avec son critère de passage vérifiable et son livrable.

Gabarit de la fiche projet à remplir :

Rubrique	Contenu attendu
Objet et périmètre	Ce que fait le projet, quelles filiales, quels flux inter-filiales ou vers des tiers
Données et besoins DICT (disponibilité, intégrité, confidentialité, traçabilité)	Données manipulées, lues au dossier de filiale (données de patients, mouvements de stocks pharmaceutiques, coordonnées bancaires, données citoyennes, selon le projet), et leurs besoins de disponibilité, intégrité, confidentialité, traçabilité
Régime du projet	Développer, acheter ou faire développer, et ce que ce choix implique
Jalons de sécurité	Les six jalons, chacun avec sa question et son critère de passage vérifiable
Responsabilités	Qui tient chaque jalon, responsable ultime unique par décision (gouvernance de séance 1)
Points d'arbitrage	Les désaccords prévisibles et l'instance qui tranche

Pour la ligne des jalons, remplir le tableau suivant. Un critère de passage vérifiable se démontre par un fait, pas par une déclaration.

Jalon	Question posée	Critère de passage vérifiable	Livrable produit au jalon
J1 Qualification	Quelles données, quels besoins DICT, quel niveau d'analyse ?	À compléter	À compléter
J2 Architecture	Cloisonnement, authentification, journalisation prévus ?	À compléter	À compléter
J3 Contractualisation	Exigences de sécurité au contrat, si tiers ?	À compléter	À compléter
J4 Recette	Exigences démontrées, pas seulement déclarées ?	À compléter	À compléter
J5 Exploitation	Qui maintient, surveillance, corrige, dans quels délais ?	À compléter	À compléter
J6 Fin de vie	Données restituées ou détruites, accès révoqués ?	À compléter	À compléter

Pour un système soumis à homologation, le critère de passage du jalon J4 est la décision d'homologation, prononcée sur le dossier de recette par l'autorité désignée en séance 4 ; la fiche le dit en toutes lettres.

✓ Pièce 2 : les exigences pour le contrat d'infogérance

Reprendre le contrat travaillé au TD, celui du prestataire le plus exposé de la filiale instruite. Rédiger le jeu d'exigences de sécurité à inscrire au cahier des charges de son renouvellement ou de son avenant, dont le prestataire devra démontrer la couverture dans son Plan d'Assurance Sécurité. Chaque exigence est tracée vers un scénario stratégique du TP précédent, un écart de l'audit de la séance 4, ou un silence du contrat constaté au dossier : la colonne de justification est le cœur de l'exercice. Compléter par le dispositif qui fait vivre ces exigences après signature. À produire : le tableau des exigences vérifiables tracées et le tableau du dispositif de surveillance du tiers, renseignés.

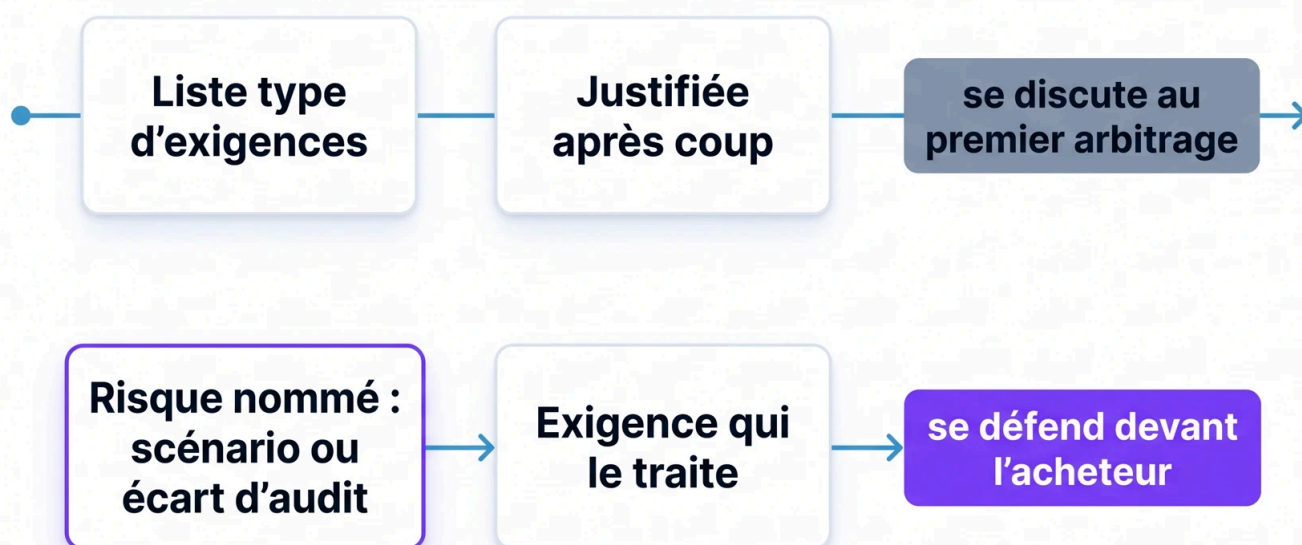
Exigence	Formulation vérifiable	Justification (scénario stratégique, écart d'audit S4, ou silence du contrat co
Réversibilité	À compléter	À compléter
Droit d'audit	À compléter	À compléter
Notification d'incident	À compléter	À compléter
Traçabilité et comptes nominatifs	À compléter	À compléter
Encadrement de la sous-traitance	À compléter	À compléter

Compléter la pièce 2 par le dispositif de surveillance du tiers, tel que le livrable D6 l'exige : c'est lui qui fait vivre les exigences après la signature. Remplir ce tableau :

Élément du dispositif	Contenu attendu
Indicateur 1	Libellé, source de la donnée, fréquence de relevé
Indicateur 2	Idem
Indicateur 3	Idem
Comité de suivi	Périodicité, participants, ce qui s'y décide
Preuves exigibles chaque année	Ce que le prestataire remet sans qu'on le lui demande
Ce qui reste au donneur d'ordre	Les décisions et contrôles qui ne se délèguent pas, même en infogérance partielle

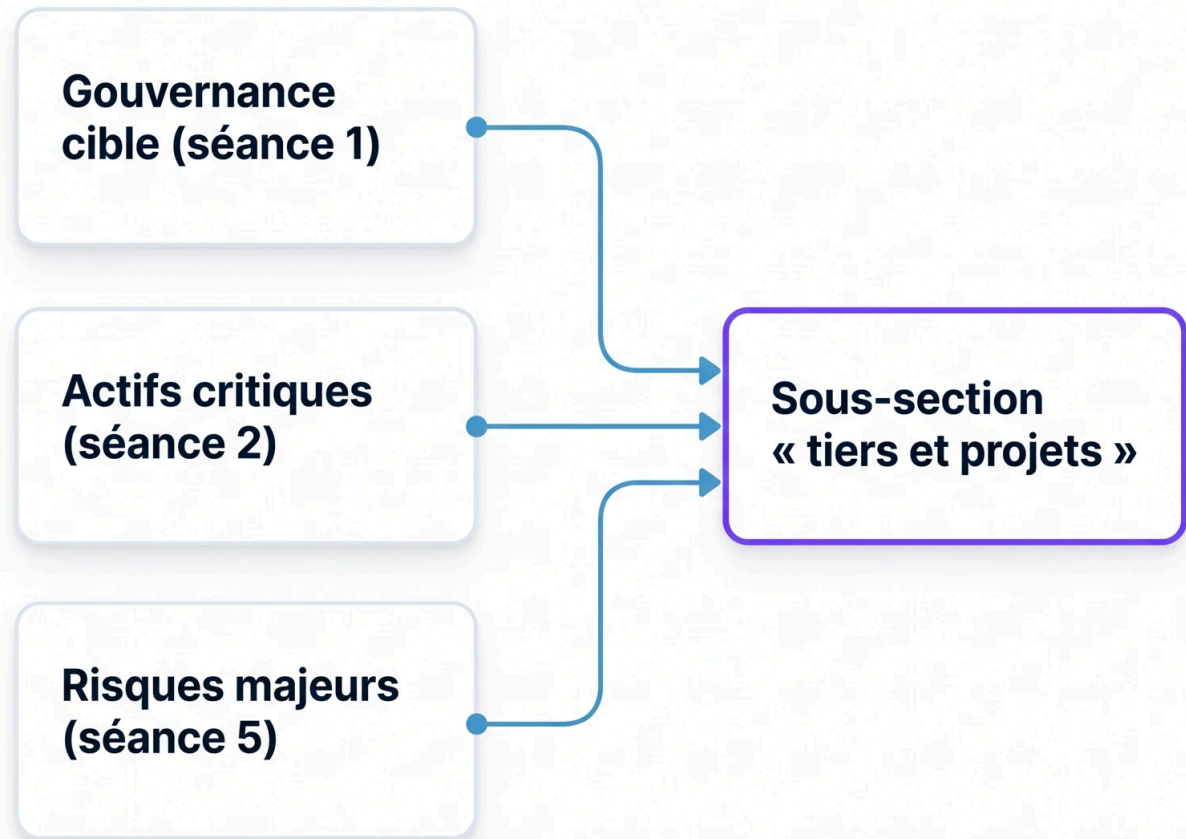
✓ Rédaction : trente minutes, deux pièces, zéro exigence orpheline

Compter quinze minutes par pièce et travailler depuis les documents, pas de mémoire : la fiche projet puise dans les besoins DICT de la séance 2 et les scénarios du TP précédent, les exigences dans l'audit de la séance 4 et le contrat du TD. Pour la fiche projet, commencer par le jalon J1 ; pour les exigences, partir du scénario stratégique et remonter vers l'exigence, jamais l'inverse. Une exigence sans justification vaut zéro.



✓ Note de stratégie (15 minutes)

Dernier quart d'heure, rituel du module : enrichir la note de stratégie du groupe d'une sixième sous-section, « tiers et projets », une demi-page au plus, sans rien recopier du D6. Elle porte la position du groupe sur ses tiers et ses projets et s'articule explicitement aux sous-sections des séances précédentes, la gouvernance de la séance 1 et les actifs critiques de la séance 2. Les contraintes demeurent : trois à cinq pages de texte au total, tableaux et annexes non comptés, rien ne se supprime, tout s'amende avec une phrase de justification. À produire : la sous-section « tiers et projets », articulée aux sous-sections antérieures et tenant dans le volume global.



Corrigés et critères d'évaluation – cliquer pour révéler